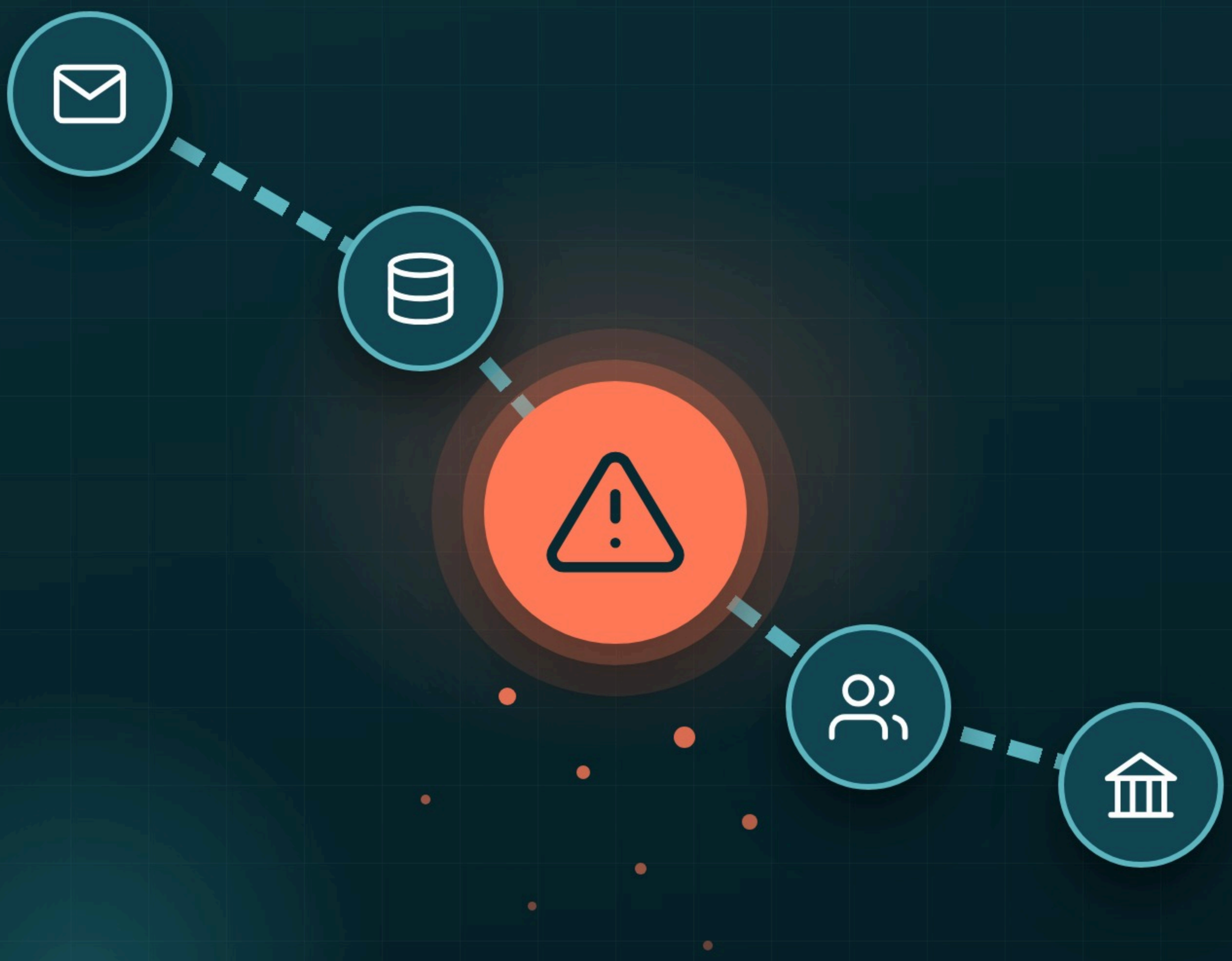
THE

THIRD-PARTY RISK PROBLEM



How Your Suppliers Can Put Your Business Data at Risk

ZIRLANDIA MILKOVIC

THE

THIRD-PARTY RISK PROBLEM

How Your Suppliers Can Put Your Business Data at Risk

ZIRLANDIA MILKOVIC

The Third-Party Risk Problem
How Your Suppliers Can Put Your Business Data at Risk

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 30 October 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Risk You Did Not Build 5
Who This Book Is For 7
How to Use This Book 8
The One-Page Supplier Check 10

CHAPTERS

1. The Supplier Problem 11
2. Map Your Suppliers 15
3. Vendor Security Assessments 21
4. GDPR Processor Agreements 26
5. SaaS and Cloud Supplier Risks 32
6. Watching Your Suppliers 37
7. When a Supplier Is Breached 40
8. Leaving a Supplier 45
9. The Practical Supplier Assessment Checklist 48
10. Your 30-Day Supplier Risk Plan 52
11. Five Case Files 55

CLOSING

Conclusion: Trust, Verified 58

APPENDICES

Appendix A: Supplier Inventory Template 59
Appendix B: Supplier Tiering Sheet 60
Appendix C: Supplier Assessment Record 61
Appendix D: Processor Agreement Checklist (Article 28) 62
Appendix E: Short Supplier Security Questionnaire 64
Appendix F: Supplier Offboarding Checklist 66
Appendix G: Supplier Breach Log 67

BACK MATTER

Glossary 68
A Note on GDPRGard.eu 70
About the Author 71
Notes and Sources 72

Educational Disclaimer

This book is practical, educational guidance for small and medium-sized businesses. It is not legal, security, audit or data-protection advice, and it does not create a professional relationship between the author and the reader.

Data-protection law, supplier contracts, security standards and regulator guidance differ by country and change over time. Check the current position with a qualified adviser or your supervisory authority before relying on anything here for a decision that matters, especially about international transfers, breach reporting and contract terms.

Following the steps in this book may reduce your risk. It cannot guarantee that a supplier will not be breached, that a contract will protect you in every case, or that you will meet every legal duty. Checklists and clause lists are starting points to adapt, not finished legal documents.

Every business, person and product used in a worked example is **fictional** and is labelled as such. Where the book describes a real incident or rule, it is sourced in the notes at the back; where it gives a recommendation, it says so.

Introduction: The Risk You Did Not Build

You can do almost everything right and still lose your customers' data.

You can lock down your own laptops, train your staff, and write a sensible privacy policy. Then a company you have never visited, running software you pay for by card each month, has its systems breached, and your customer list is in the hands of someone you have never heard of. The headline will carry your supplier's name. The email to your customers will carry yours.

That is the third-party risk problem. Modern businesses are not single buildings with a lock on the door. They are chains: an accounting app, a payment processor, an email platform, a cloud host, a support desk, an outsourced payroll bureau, a marketing tool, and a handful of freelancers with access to shared folders. Each link holds some of your data or some of your ability to operate. Each link is run by people whose security you have never examined.

Under the GDPR, handing data to a supplier does not hand over the responsibility. If you decide why and how personal data is used, you remain the **controller**, and the law expects you to choose suppliers carefully, to put the right contract in place, and to keep an eye on them afterwards. A regulator who investigates a supplier breach will quite reasonably ask what *you* did before it happened.

This book gives you a calm, proportionate way to answer that question. It is written for owners and managers who are not security specialists and do not have a legal department. It is built around five steps that you can run with a spreadsheet, a few emails and an hour a week:

Map, Test, Bind, Watch, Exit.

You will list your suppliers, rank them by how much damage they could do, assess the ones that matter, make sure the contract says what the GDPR requires, keep checking, and plan for the day you leave. Along the way you will find the clause lists, questionnaires and checklists to do each step, and five fictional case files to practise on.

You do not need to distrust every supplier. Most are honest, competent and doing their best. The point is to stop trusting by default, and to replace hope with evidence.

Who This Book Is For

This book is for you if you run or help run a small or medium-sized organisation in Europe or the UK and any of the following is true:

- You use cloud software, apps or online services that hold customer, employee or business data.
- You send personal data to an outsourced provider, such as payroll, IT support, marketing, a call centre or a delivery partner.
- You are asked to complete supplier questionnaires by larger customers, or you expect to be.
- You have signed up to a vendor's standard terms without reading the data-protection section, and you suspect you are not alone.
- You are responsible for privacy or security as one part of a wider job.

It is not written for enterprise security teams with dedicated vendor-risk platforms. If you have one, you will find the checklists a useful sanity test, but you will already own more sophisticated tools.

A note on terms. "Supplier", "vendor" and "third party" are used interchangeably. "Processor" has its GDPR meaning: an organisation that processes personal data on your behalf and on your instructions. All suppliers are third parties; only some are processors.

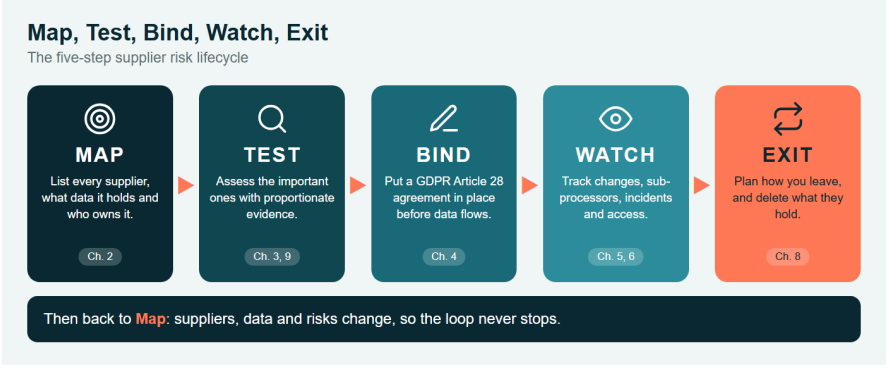
How to Use This Book

If you have one hour, read Chapter 1, then go straight to Appendix C (the assessment checklist) and Appendix D (the processor-agreement checklist), and use them on the most important supplier you have.

If you have one weekend, read the whole book and complete Appendix A (the supplier inventory) and Appendix B (the tiering sheet). These two documents are the foundation for everything else, and many small businesses find they have never written their supplier list down in one place.

If you are working through this with a team, assign each chapter to one person, then use the 30-day plan in Chapter 9 to share the work.

The book follows five steps, shown below. Each chapter says which step it belongs to.



The five-step supplier risk lifecycle

Look for these boxes:

> **The rule.** A short principle worth remembering.
>
> **Fictional.** A worked example using invented businesses.

Checklists use empty boxes you can tick. Blank lines are for notes if you print the page.

The One-Page Supplier Check

Before you sign up to a new supplier, or renew an old one, ask these questions. If you cannot answer one, that is your next task.

- ☐ What data will this supplier hold or see, and how sensitive is it?
- ☐ What could we not do if they were offline for three days?
- ☐ Do they act as our **processor**? If yes, is there a written data-processing agreement?
- ☐ Do they use **sub-processors**, and do we know who they are and where they are?
- ☐ Will personal data leave the EEA or UK, and what is the transfer mechanism?
- ☐ What evidence of security do they offer, and is it current and relevant to the service we are buying?
- ☐ Will they tell us quickly if they are breached, and does the contract say how quickly?
- ☐ Is multi-factor authentication switched on for every account we control?
- ☐ Can we get our data out, in a usable form, if we leave?
- ☐ Who in our business owns this supplier relationship?

CHAPTER 1

The Supplier Problem



> **Fictional.** Harlow & Finch, BrightDesk and every person below are invented for teaching. They are not real businesses or incidents.

Harlow & Finch is a fourteen-person design studio. It keeps its client files in a shared drive, sends newsletters through an email platform, runs invoices through an online accounting app, and uses a customer-support tool called BrightDesk to answer enquiries. Nobody chose these tools in a meeting. Each was added by someone who needed it, with a card and a free trial.

One Tuesday morning an email arrives from BrightDesk. It says that "a subset of customer support data" may have been accessed by an unauthorised party, that the investigation is continuing, and that no action is required. It does not say which customers are affected, what data was taken, or when the access began.

The managing director, Ines, has three questions. *What did we put in there? Is there a contract that says they must tell us more? How long do we have before we must tell anyone else?*

Nobody at Harlow & Finch can answer any of the three. The support tool holds names, email addresses, order references and, because clients sometimes paste them into tickets, a few attachments with passport scans for a visa-letter project. There is no signed data-processing agreement, only the click-through terms. No one knows whether BrightDesk uses sub-processors, or where the data is hosted.

The breach did not start at Harlow & Finch. But the duty to find out what happened, assess the risk to individuals and, if necessary, report within 72 hours falls on Harlow & Finch as controller. The 72-hour clock starts when the studio becomes *aware* of a breach, not when it finishes investigating.[1]

This book is about being in the other version of that story, the one where Ines knows the answers on Tuesday morning.

Why suppliers are now the weak point

Attackers go where the effort is lowest. A well-run small business is a harder target than the larger company that holds its data on behalf of thousands of customers. A supplier is one door that opens onto many rooms.

Real incidents show the pattern, and none requires you to be careless:

- **Target (2013).** Attackers reached the retailer's network using credentials stolen from a refrigeration and heating contractor.[2]
- **SolarWinds (2020).** Attackers inserted malicious code into updates of a widely used network-monitoring product, so that customers who did the sensible thing and installed the update received the compromise.[3]
- **Kaseya (2021).** Criminals abused a remote-management tool used by IT service providers, pushing ransomware to the providers' own customers.[4]
- **MOVEit (2023).** A vulnerability in a file-transfer product was exploited at scale, and the organisations hurt included those whose suppliers used it, as well as those who used it directly.[5]
- **Capita (2023).** After a cyber-attack on the outsourcing company, the UK Information Commissioner fined Capita £14 million in October 2025. The ICO said data of around six million people was

taken, most of it held by Capita as a processor on behalf of other organisations, and that Capita had been slow to respond to a high-priority alert.[6]

- **CrowdStrike (2024).** A faulty security-software update crashed millions of Windows machines worldwide. There was no attacker at all: a supplier's mistake was enough to stop businesses operating.[7]

These examples differ in cause. A stolen password, a poisoned update, an unpatched flaw, a slow response and a bad software release are very different failures. What they share is the shape: **the harm arrived through a relationship the victim had chosen and trusted.**

Three kinds of third-party risk

It helps to separate the ways a supplier can hurt you, because the right control for each is different.

Risk	What it looks like	Typical control
Confidentiality	A supplier is breached or misuses the data you gave it	Assessment, contract, access limits, encryption
Availability	A supplier goes down, is attacked or fails, and you cannot work	Resilience questions, backups, exit plan, alternatives
Compliance	A supplier's behaviour makes *you* non-compliant: no processor contract, hidden sub-processors, unlawful transfers	GDPR processor agreement, transfer checks, records

A fourth risk runs through all three: **concentration**. If five of your tools quietly sit on the same cloud platform, one outage is five outages.

What the law expects of you

The GDPR does not say "never use suppliers". It says that if you use a processor, you must use one that provides *sufficient guarantees* to implement appropriate measures, and you must have a contract that binds them (Article 28).[8] It also sets a general duty to be able to *demonstrate* compliance (Articles 5(2) and 24).

In practice a regulator, a customer's auditor or an insurer will ask a short list of questions after an incident:

1. Did you know this supplier held the data?
2. Did you check them before you chose them?
3. Was there a compliant contract?
4. Did you keep checking?
5. Did you respond properly when it went wrong?

The rest of this book exists so that you can answer "yes" to each, with a document to point at.

> **The rule.** You can outsource a task. You cannot outsource the responsibility for what happens to the data.

CHAPTER 2

Map Your Suppliers



Step 1 of 5: Map.

You cannot manage a risk you cannot see. The first job is a list of every supplier that touches your data or your operations, and a short note on what each one does. This sounds trivial. In practice, most small businesses discover that the list is longer than anyone expected.

Finding the suppliers you have forgotten

Do not rely on memory. Pull from sources that already exist:

- **Card and bank statements.** Search twelve months for recurring charges and annual renewals. This is the single most productive source.
- **Accounts payable.** Every supplier you have paid is a candidate.
- **Single sign-on logs.** "Sign in with Google" and "Sign in with Microsoft" records show which apps staff have connected to company accounts.
- **Email.** Search for "welcome to", "your subscription", "verify your email" and "invoice".
- **Your own team.** Ask each department head: *what tools do you use that IT or finance may not know about*? Make it clear this is a mapping exercise, not a hunt for rule-breakers. People who fear blame will hide tools.
- **Freelancers and agencies.** Include individuals who have a login to anything.

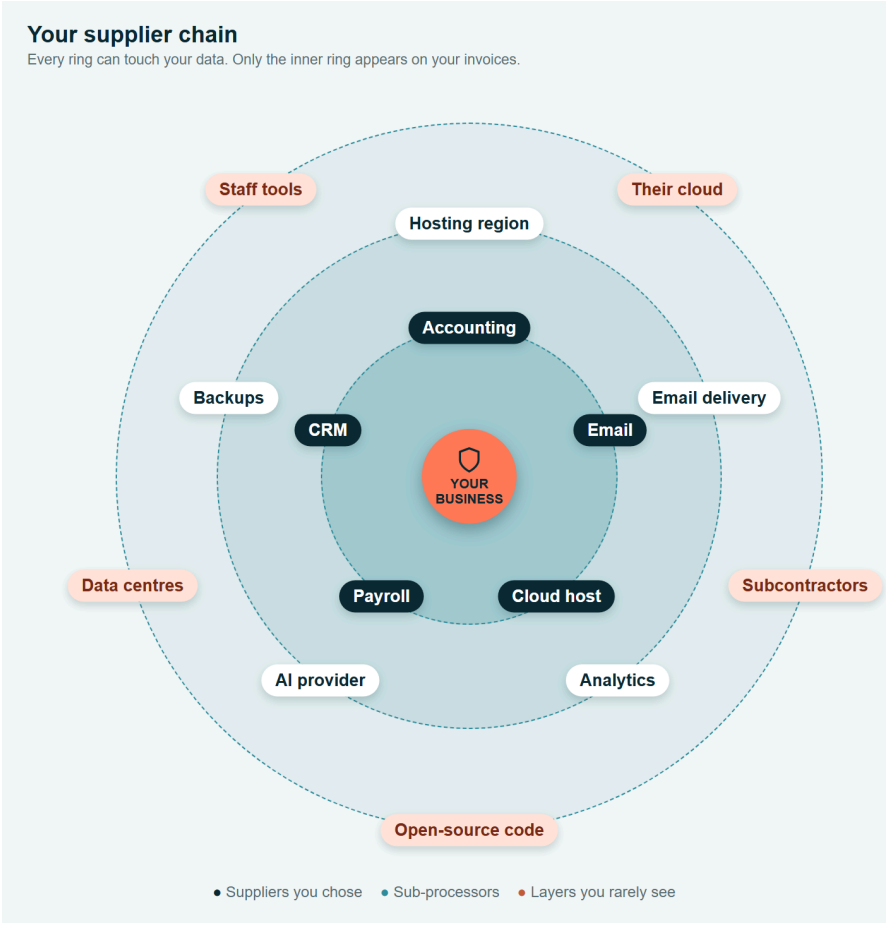
Expect to find "shadow" tools, adopted by one team on a free plan, that now hold real customer data.

What to record

Keep it small enough that it will actually be kept up to date. Appendix A has a full template. At minimum, for each supplier record:

Field	Example
Supplier and product	BrightDesk, helpdesk platform
Business owner	Ines, Managing Director
What they do for us	Handles customer support tickets
Personal data held	Names, emails, attachments; occasionally ID scans
Special-category data?	Possible, by accident
Where data is stored	Unknown, to be confirmed
Sub-processors known?	No
Contract and DPA in place?	Click-through terms only
Renewal date	14 March
Tier	To be set below

The "where is the data and who else touches it" columns are the ones most often blank. That is information, not failure. A blank is a task.



Your supplier chain has more links than you can see

Fourth parties: the suppliers behind your suppliers

Your supplier uses suppliers. A helpdesk tool may sit on a cloud host, use an email-delivery service, a payment processor, and an AI provider for its "smart reply" feature. Under the GDPR these are **sub-processors**. The European Data Protection Board has said that a controller should have the identity of all processors and sub-processors readily available, and that the duty to verify that each provides sufficient guarantees applies whatever the level of risk.[9]

The initial processor remains fully liable to you for its sub-processors, but that is cold comfort if you cannot even say who they are.

Most vendors publish a sub-processor list on a trust or legal page. Make it part of your record, and ask to be notified of changes.

Rank by damage, not by size

Not every supplier deserves the same attention. A company that delivers stationery and a company that hosts your customer database should not receive the same questionnaire.

Tier your suppliers by what would happen if they failed or were breached. Use three tiers:

Tier	Test	Example	Depth of checks
1 – Critical	Holds sensitive or large amounts of personal data, **or** you could not operate without it for several days	Cloud host, payroll bureau, CRM, payment processor	Full assessment, written DPA, annual review, exit plan
2 – Important	Holds some personal data or supports a significant process	Email marketing, accounting app, scheduling tool	Short questionnaire, DPA, review at renewal
3 – Low	No personal data and easily replaceable	Stationery, a font service	Basic due diligence, contract at renewal



Impact and dependence decide the tier

Two questions place a supplier quickly. **How bad is it if their data is exposed?** And **how bad is it if they are unavailable?** If either answer is "severe", the supplier is Tier 1. Appendix B has a scoring sheet.

> **The rule.** Spend your effort in proportion to the damage a supplier could do, not the size of the invoice.

Small suppliers can be Tier 1

A one-person bookkeeper with access to your bank and your payroll is more dangerous than a large vendor with strong controls and limited access. Judge by access and data, not brand.

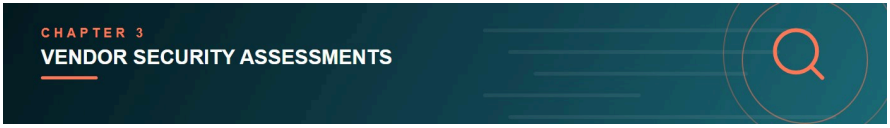
Make someone the owner

Every supplier needs one named person inside your business: the one who knows why it is used, receives its emails, approves changes and renews or ends the contract. Without an owner, nobody notices

when a supplier changes its terms, adds a sub-processor, or gets breached.

CHAPTER 3

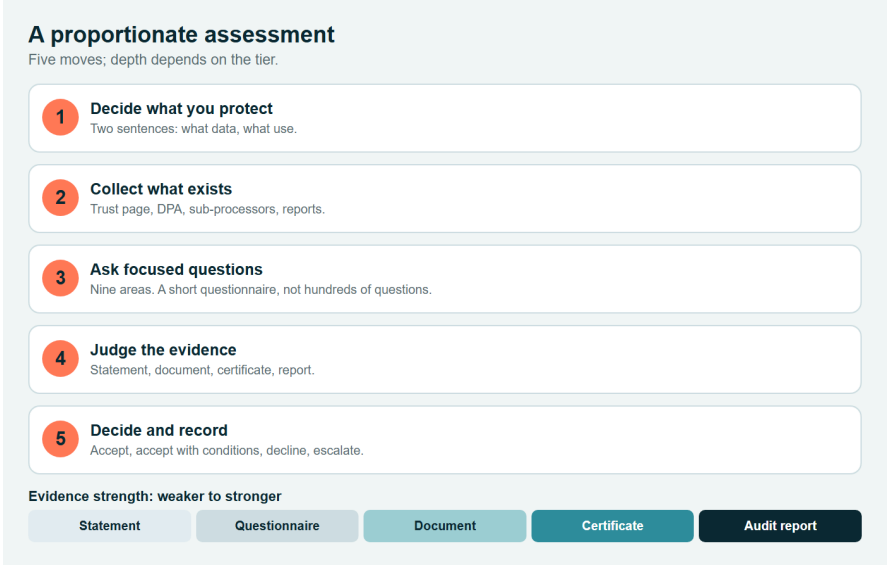
Vendor Security Assessments



Step 2 of 5: Test.

A vendor security assessment answers one question: **can we reasonably trust this supplier with this data or this process?** It is not an exam the supplier passes or fails. It is a structured way of collecting evidence, noticing gaps and deciding what to do about them.

A good assessment is proportionate. A Tier 1 supplier gets the full treatment. A Tier 3 supplier gets a glance. The method below scales in both directions.



A proportionate assessment in five moves

Move 1: Decide what you are protecting

Before you send a questionnaire, write two sentences: *what data will they hold* and *what will they do with it*. A vendor that only receives first names for a newsletter is a different case from one that stores health records. Everything you ask next follows from those two sentences.

Move 2: Collect what already exists

Reputable vendors have answers ready. Look first at:

- Their **trust centre** or security page.
- Their **privacy notice** and **data-processing agreement**.
- Their **sub-processor list**.
- Public certification statements or audit reports they will share, usually under a non-disclosure agreement.
- Their **status page** history, which shows how often the service has had outages and how openly they report them.

Only after reading these should you ask questions. It is both polite and efficient.

Move 3: Ask the right questions

Long questionnaires of hundreds of questions are common in large enterprises and unhelpful for small ones. Nobody reads the answers, and suppliers respond by pasting the same standard document to everyone. A focused set of questions tells you more. Appendix E contains a ready-to-use short questionnaire. These are the areas that matter:

Area	What you are trying to learn
Governance	Who is responsible for security? Is there a documented policy and a way to report issues?

Area	What you are trying to learn
Access control	Is multi-factor authentication required for staff and offered to customers? How is access to your data limited and logged?
Data protection	Is data encrypted in transit and at rest? Where is it stored? Who holds the keys?
Vulnerability management	How are flaws found and patched? Is there independent testing?
Incident response	Is there a tested plan? How soon would you be told of a breach?
Resilience	What are backups, recovery times and uptime commitments?
People	Are staff screened and trained? How do contractors get access?
Sub-processors and location	Who else touches the data, and in which countries?
Exit	How do we export our data, and how is it deleted afterwards?

Move 4: Judge the evidence

Evidence comes in different strengths. From weakest to strongest:

1. **A statement.** "We take security seriously." Worth nothing alone.
2. **A completed questionnaire.** The supplier's own account. Useful, but self-reported.
3. **A policy or document.** Shows intent. Check it is dated and applies to this service.
4. **A certificate.** Independent assessment against a standard.
5. **An audit or test report.** Detail you can read: what was tested, by whom, and what was found.

Reading certificates properly

Certificates are helpful and widely misunderstood. Ask three things of any certificate.[10]

- **Scope.** Does it cover the *product and location* you actually use? A certificate for a company's head office says little about a particular cloud service.
- **Currency.** Is it in date? Who issued it?
- **Type.** For SOC 2, a *Type I* report describes the design of controls at a point in time. A *Type II* report tests whether they operated effectively over a period, typically several months. Type II is the more meaningful of the two.

Evidence	What it tells you	What it does not
ISO/IEC 27001 certificate	An information-security management system exists and was audited	That every control is strong, or that your service is in scope
SOC 2 Type II report	Controls were tested over a period, with any exceptions noted	That the exceptions don't matter to you
Penetration-test summary	Someone attacked the system on a date	That nothing has changed since
Cyber Essentials (UK)	Basic technical controls are in place	Depth or resilience

A supplier without any certificate is not automatically unsafe. Many small, careful vendors have none. The absence simply means you must rely on other evidence, such as direct answers, a demonstration, or the maturity of what they publish.

Move 5: Decide and record

An assessment ends with a decision, not a score. Choose one:

- **Accept.** Risks are within what you are willing to carry.
- **Accept with conditions.** You will use the supplier if specific actions happen: switch on multi-factor authentication, restrict the data you send, sign the DPA, or fix a gap by a given date.
- **Decline or replace.** The risks outweigh the benefit.
- **Escalate.** You cannot judge without specialist help.

Write the decision, the date, the reasons and the person who made it. That one paragraph is often what a regulator or customer most wants to see.

Red flags worth pausing for

- The supplier cannot say where your data is stored.
- No multi-factor authentication for their own staff or for you.
- A refusal to sign any data-processing agreement, or to name sub-processors.
- Vague answers to the incident question: "we would notify you as appropriate".
- Admin access shared between several staff members through one login.
- No way to export your data.
- A breach history that was handled badly, or never acknowledged.
- Security claims on the website that nothing else supports.

One red flag is a question. Several together are an answer.

> **The rule.** Ask for evidence at the strength the risk deserves, and write down what you decided.

Questions suppliers ask in return

Large customers will send *you* questionnaires too. The better you understand the process from the buyer's side, the easier it is to answer well. Keep a standing document of accurate answers: your security measures, your sub-processors, your breach process, your certifications. Update it twice a year.

CHAPTER 4

GDPR Processor Agreements



Step 3 of 5: Bind.

A security assessment tells you what a supplier does. A contract binds them to keep doing it. Under the GDPR, when a supplier processes personal data on your behalf, a written contract is not optional.

Controller or processor?

The first question is who does what.[11]

- A **controller** decides the purposes and means of processing: *why* the data is used and *how*.
- A **processor** processes personal data on behalf of the controller and on its documented instructions.
- **Joint controllers** decide purposes and means together and must set out their respective responsibilities in a transparent arrangement (Article 26).

Examples in a typical small business:

Supplier	Usual role	Why
Payroll bureau	Processor	Processes employee data on your instructions
Cloud hosting	Processor	Stores your data, does not decide what it is for
Email marketing platform	Processor	Sends your messages to your list

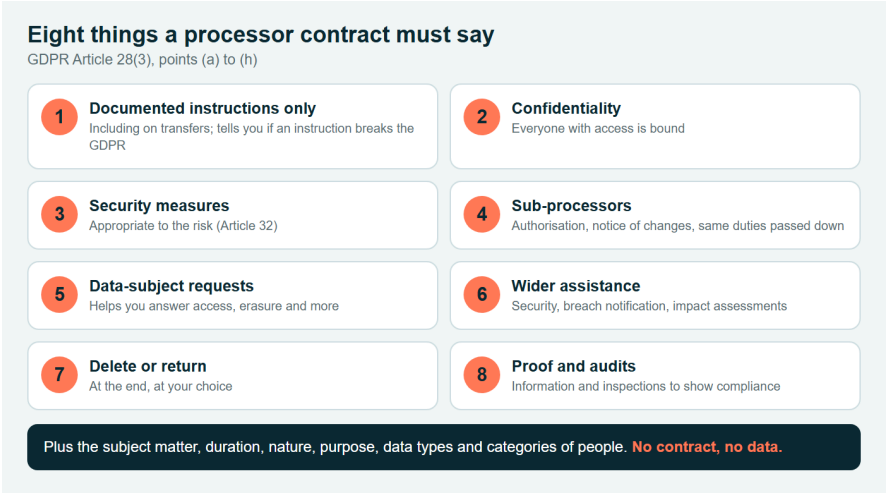
Supplier	Usual role	Why
Accountant	Often an independent controller, or a processor, depending on the arrangement	Has professional duties of its own; check the engagement terms
Payment service provider	Often an independent controller for its own purposes	It processes for its own regulatory duties as well
Analytics provider using your data for its own product improvement	May be a controller or joint controller for that use	It decides purposes of its own

The label in a contract does not decide the role. The facts do. A supplier that quietly uses your data for its own purposes can become a controller in its own right (Article 28(10)), and your contract should forbid it.

What Article 28 requires

Where processing is carried out by a processor, the controller must use only processors providing sufficient guarantees, and the processing must be governed by a binding contract that sets out the subject matter, duration, nature and purpose of processing, the type of personal data, the categories of data subjects, and the controller's obligations and rights.[8]

The contract must also require that the processor:



The eight things a processor contract must say

1. **Acts only on documented instructions**, including as to transfers to third countries, unless law requires otherwise, and tells you if an instruction would infringe the GDPR.
2. Ensures that people authorised to process the data are **committed to confidentiality**.
3. Takes all the **security measures** required by Article 32.
4. Respects the **conditions for engaging another processor** (sub-processors).
5. **Assists you with data-subject requests**, such as access and erasure.
6. **Assists you with your obligations** on security, breach notification, data-protection impact assessments and prior consultation.
7. **Deletes or returns** all personal data at the end of the services, at your choice, and deletes existing copies unless law requires storage.
8. **Makes available all information** needed to demonstrate compliance and allows for and contributes to **audits, including inspections**.

If a contract is missing any of these, it is not a compliant processor contract, however professional it looks.

Reading a vendor's standard DPA

Most SaaS vendors offer a standard data-processing agreement, often built into their terms or available to download and sign online. You will rarely negotiate it as a small customer. You can still *read* it, and a few clauses deserve particular attention:

Clause	What to look for
Instructions	Does the processor act only on your instructions? Any wording that lets it use data for its own product development or "service improvement" needs scrutiny.
Sub-processors	Is there a list? Is there a notice period for changes, and a right to object? "General authorisation" with notice is common and acceptable.
Breach notification	Is there a time limit? "Without undue delay" is the legal floor. Many vendors commit to a fixed period, such as 24 or 48 hours. A defined time is better than none.
Audit	Are audits allowed? Most large vendors offer audit reports instead of on-site visits. That can be reasonable if the reports are meaningful.
Deletion	How long after termination is your data deleted, and can you get an export first?
Transfers	Which transfer mechanism applies, and are the standard clauses incorporated?
Liability	Is liability capped, and is the cap realistic against the data involved? This is mostly a commercial point.
Governing law	Which law and courts apply?

Sub-processors in practice

The processor must not engage another processor without your prior specific or general written authorisation. Where authorisation is general, the processor must tell you of intended changes and give

you the chance to object (Article 28(2)). The processor must impose the same data-protection obligations on the sub-processor, and it remains fully liable to you for the sub-processor's performance (Article 28(4)).

In its 2024 opinion, the EDPB made clear that controllers cannot treat the supply chain as someone else's problem: they should be able to identify every processor and sub-processor, and verify that each provides sufficient guarantees. A copy of every sub-processing contract is not automatically required, but you should ask for one where there are doubts or a regulator asks.[9]

A practical routine. Subscribe to the vendor's sub-processor change notifications. When one arrives, a named person checks: who is this, what do they do with our data, where are they, and do we object? Record the answer.

International transfers

If a supplier or its sub-processors process data outside the EEA, a transfer mechanism is needed (Chapter V of the GDPR). The common ones are:

- An **adequacy decision**, which means the European Commission has found a country's protection essentially equivalent. The EU–US Data Privacy Framework adequacy decision, adopted in July 2023, covers transfers to US companies that have certified under it. The General Court dismissed a challenge to it in September 2025, and an appeal to the Court of Justice was pending when this book was finalised, so it remains in force but is not beyond challenge. Verify a vendor is on the Data Privacy Framework List before relying on it.[12]
- **Standard Contractual Clauses**, adopted by the Commission in 2021, which must be accompanied by an assessment of whether the destination country's laws undermine the protection.[13]

- Less commonly, binding corporate rules or narrowly drawn exceptions.

Do not rely on a vendor saying "we are GDPR compliant". Ask: *which mechanism covers which transfer?* If the answer is "we are certified under the Data Privacy Framework", check. If it is "we use Standard Contractual Clauses", check they are in the signed contract.

Who pays when it goes wrong

The GDPR gives individuals a right to compensation (Article 82). A controller is liable for damage caused by processing that infringes the GDPR. A processor is liable only where it has not complied with processor-specific obligations or has acted outside or against lawful instructions. Where both are responsible, each can be held liable for the entire damage so that the individual is compensated, with a right of recourse between them.[14]

Regulatory fines are separate. Breaches of the controller and processor obligations, including Article 28, can attract fines of up to €10 million or 2% of worldwide annual turnover, whichever is higher. Unlawful transfers fall in the higher tier of up to €20 million or 4% (Article 83).[15] Most small-business fines are far below these ceilings, but they show how seriously the law treats the supply chain.

When you are the processor

If you also process data for customers, you are on the other side of this table. Expect to be asked for a DPA, a list of your sub-processors, your breach commitments and your security evidence. Prepare one standard pack and use it.

> **The rule.** No personal data should flow to a processor until the contract is signed.

CHAPTER 5

SaaS and Cloud Supplier Risks



Most of your suppliers now arrive as software you rent, not software you install. That brings real benefits: patches happen without you, costs are predictable, and small businesses use tools that were once reserved for large ones. It also changes the risk in ways that are easy to miss.

The shared responsibility trap

Cloud and SaaS providers describe a **shared responsibility model**. The provider secures the platform. You are responsible for how you use it. The more the provider does for you, the more tempting it is to assume they do everything.

Who secures what

A typical split. Your provider's own documentation is the authority.

	SaaS software you use	PaaS platform you build on	IaaS servers you rent
Your data	YOU	YOU	YOU
Users and access (MFA)	YOU	YOU	YOU
Settings and sharing	YOU	YOU	YOU
Application	PROVIDER	YOU	YOU
Operating system, runtime	PROVIDER	PROVIDER	YOU
Network and hardware	PROVIDER	PROVIDER	PROVIDER
Physical data centre	PROVIDER	PROVIDER	PROVIDER

Even in SaaS, **your data, your accounts and your settings stay with you.**

Who secures what in SaaS, platform and infrastructure services

In practice, the supplier looks after its data centres, hardware and core software. You look after:

- **Who has accounts**, and whether leavers are removed.
- **How accounts are protected**: strong, unique passwords and multi-factor authentication.
- **Configuration**: sharing settings, public links, storage permissions, integrations.
- **What data you put in** and whether you should have.
- **Backups of your own data** where the service does not provide the kind you need.

Many serious cloud incidents begin on the customer side of that line. In 2024, a wave of data thefts from customers of a cloud data platform was linked by the security firm Mandiant to stolen credentials on customer accounts that did not have multi-factor authentication enabled. The platform itself had not been breached in the way many first assumed.[16] The lesson is not that the vendor is blameless or at fault. It is that **a strong vendor with weak customer settings is still a weak outcome.**

> **The rule.** Buying a secure service is only half the job. The other half is switching the security on.

Six questions for any SaaS or cloud supplier

1. Where is our data, and who can reach it? Ask for the hosting regions, the sub-processors and any locations from which support staff can access your data. "Hosted in the EU" can still mean accessed from elsewhere.

2. Can we control access properly? Look for multi-factor authentication, single sign-on, role-based permissions and an audit log you can actually read. A tool that has only a single admin login is a risk by design.

3. Is our data separated and encrypted? Ask whether data is encrypted in transit and at rest, and whether customers' data is logically separated. For sensitive data, ask who controls the encryption keys.

4. What happens when things go wrong? Ask for uptime history, recovery targets, backup frequency and the incident-notification commitment.

5. What else will they do with our data? Check the terms for rights to use data for analytics, product improvement or machine-learning. "Service improvement" can be broad.

6. How do we leave? Check the export format, the time to export, the deletion period and any fees. Chapter 8 returns to this.

Concentration and the hidden dependency

Your suppliers are probably less independent than they look. Your CRM, your forms tool and your e-commerce platform may all run on the same large cloud provider. An outage there is a multi-supplier outage.

You rarely control this, but you can ask the question for Tier 1 services: *what do we depend on, and what is our fallback if it is down for a day or a week?* A fallback may be as modest as "we can invoice by hand and take payments by phone for three days".

For financial-sector firms, the EU's Digital Operational Resilience Act has applied since January 2025 and sets detailed rules on managing information and communication technology providers, including a register of ICT third-party arrangements.[17] If you are a supplier to a regulated financial firm, expect their requirements to flow down to you in contracts.

Shadow IT and free plans

The riskiest SaaS tool in many businesses is not the expensive one that was procured. It is the free plan someone signed up to with a work email to finish a task. Free tiers often come with weaker contract terms, no data-processing agreement, and the right to use your data to improve the service.

The remedy is not prohibition, which just drives it underground. It is a quick approval route that takes a day, not a month, plus a clear list of approved tools. If saying yes is easy, staff stop sneaking.

AI features arriving in your existing tools

A new risk is that a trusted supplier adds an AI feature to an existing product, and your data begins flowing to a model provider you never assessed. This can change the supply chain overnight.

When a supplier announces AI features, ask:

- Which model provider processes our data, and are they a **sub-processor**?
- Is our data used to **train or improve** models, for us only or for everyone?
- Where is the data processed, and how long is it kept?
- Can we **switch the feature off** at account level?
- Does the DPA cover the new processing, or do we need an updated one?

Treat a change like this as a trigger for a mini-reassessment, not a marketing email to ignore.

Contract terms that quietly change

SaaS terms change by notice. A short email that begins "We are updating our terms" can alter data rights, add sub-processors or change breach commitments. Route supplier emails about terms to

the relationship owner and, for Tier 1 suppliers, read them.

NIS2 and your customers' requirements

The EU's NIS2 Directive requires covered "essential" and "important" entities to address supply-chain security, including the security-related aspects of relationships with direct suppliers.[18] Many small businesses are not themselves in scope, but if you supply a company that is, expect questionnaires and contract clauses. Treat them as a preview of good practice and answer them from your own records rather than improvising.

CHAPTER 6

Watching Your Suppliers



Step 4 of 5: Watch.

Assessment is a photograph. Suppliers change, so the picture ages. A supplier that was sound on the day you signed may be acquired, may change hosting provider, may let a certificate lapse or may suffer a breach. Monitoring means noticing, cheaply and regularly.

What to watch, and how often

The aim is a small routine, not a surveillance programme.

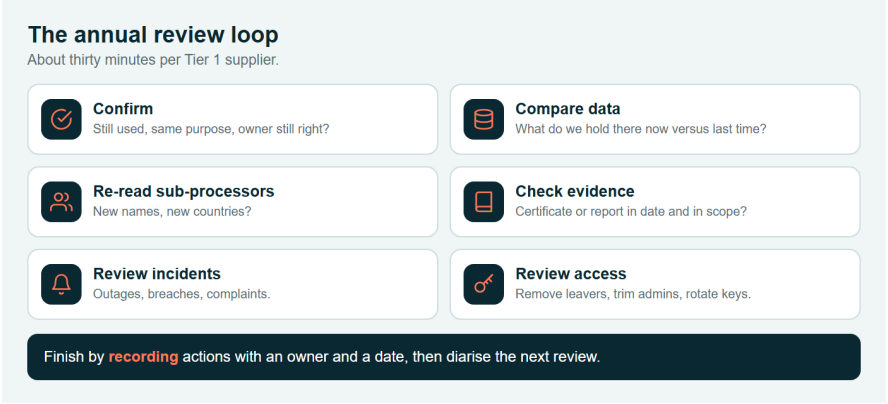
What	How	Tier 1	Tier 2	Tier 3
Sub-processor changes	Subscribe to vendor notifications	Always	Always	If available
Security and incident notices	Read emails; check the status page	Always	Always	As received
Contract and terms changes	Route notices to the owner	Read each one	Skim	As received
Certificates and reports	Check dates and scope	Annually	At renewal	Not needed
Access review	Who has accounts? Remove leavers	Quarterly	Twice a year	Annually
Breach news	Alerts for the vendor's name	Yes	Optional	No
Performance and outages	Track incidents and response	Quarterly	At renewal	No

What	How	Tier 1	Tier 2	Tier 3
Reassessment	Repeat the checklist	Annually	At renewal	Not needed

The annual review in thirty minutes

For each Tier 1 supplier, once a year the owner should:

1. Confirm the supplier is still used, and for the same purpose.
2. Check what data is held now compared with the last record.
3. Re-read the sub-processor list for changes.
4. Check the certificate or report is current and still in scope.
5. Review incidents and outages in the past year.
6. Review who has accounts.
7. Check the contract end date and notice period.
8. Record any actions with an owner and a date.



The annual supplier review loop

Triggers for an extra review

Do not wait for the calendar if any of these happens:

- The supplier announces a breach, or a customer of theirs does.
- The supplier is acquired or changes ownership.
- A new sub-processor appears in a new country.

- The supplier launches a new feature that uses your data differently.
- You plan to send a new category of data, such as employee health or children's data.
- The supplier's service has repeated outages.
- A regulator takes action against them.

Keep your own account house in order

A surprising share of supplier risk is controlled from your side:

- **Remove access when people leave**, including freelancers and agencies at the end of a project.
- **Use multi-factor authentication** on every account, with the strongest option available.
- **Limit admin rights** to the few who need them.
- **Review connected apps and integrations**, which can quietly grant a third party wide access to your data.
- **Keep an up-to-date list of API keys** and rotate them when staff change.

Record-keeping that earns its keep

Your supplier file for each Tier 1 and Tier 2 supplier should hold: the signed DPA, the assessment and decision, the sub-processor list as at your last check, the certificate or report, notes of any incident, and the review log. It takes minutes to maintain and is exactly what a regulator or customer will ask for. It also supports your record of processing activities, which must list the processors you use and, where relevant, transfers (Article 30).

> **The rule.** Trust fades with time. Reconfirm it on a schedule, and sooner when something changes.

CHAPTER 7

When a Supplier Is Breached



Sooner or later a supplier will tell you something has gone wrong. How well you handle the next hours depends largely on what you did before. This chapter is the playbook.

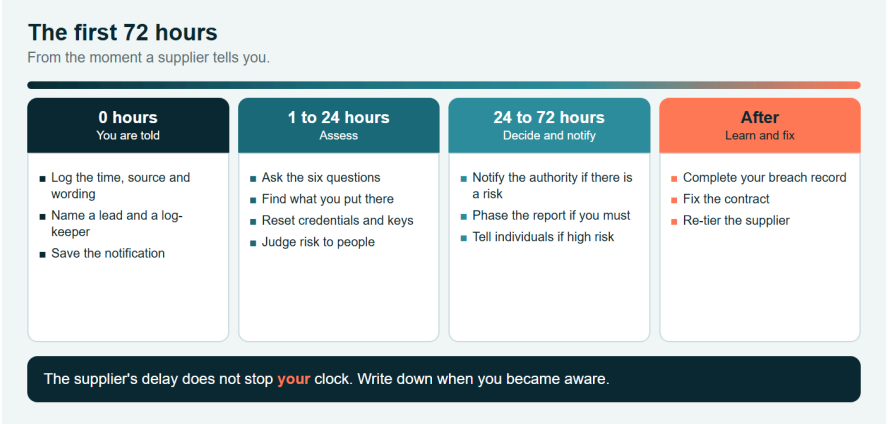
What the GDPR says about timing

Two clocks run in a processor breach.

- **The processor must notify you** "without undue delay after becoming aware" of a personal data breach (Article 33(2)).
- **You, as controller, must notify your supervisory authority** without undue delay and, where feasible, within **72 hours of becoming aware** of the breach, unless the breach is unlikely to result in a risk to individuals (Article 33(1)).
- If the breach is likely to result in a **high risk** to individuals, you must also tell the affected individuals without undue delay (Article 34).[1]

The EDPB's guidance on breach notification treats the controller as "aware" once it has a reasonable degree of certainty that a security incident has led to personal data being compromised. In practice that is often the moment a processor tells you plainly. Do not wait for a perfect report. A first notification can be phased: tell the authority what you know and add detail as you learn it.

Because the processor's delay does not pause your clock, the notification period in your contract matters. A processor that tells you on day five leaves you with a hard problem.



The first 72 hours after a supplier tells you

The first hour

1. **Log the time** you were told, who told you, and how. Everything else runs from here.
2. **Appoint one person** to lead and one to keep the log.
3. **Preserve the notification.** Save the email, the status-page post, the call notes.
4. **Ask the supplier six questions** (below).
5. **Identify what you put in the system**, using your supplier record from Chapter 2. This is where a good inventory pays off.
6. **Contain what you can**: reset passwords and API keys for that service, revoke tokens, and review recent activity.

Six questions for the supplier

#	Question
1	What happened, and when did it start and end?
2	Was our data affected, and which categories and approximate numbers?
3	Was the data encrypted or otherwise protected?
4	Has the breach been contained, and how do you know?
5	What are you doing for affected individuals, and what do you need from us?

#	Question
6	When is your next update, and who is our contact?

If the answers are vague, say so in writing and ask again with a deadline.

Hours 1 to 24: assess the risk to people

The question is not "how embarrassing is this?" but "what could happen to the people whose data this is?" Consider:

- **Type of data.** Contact details are lower risk than identity documents, financial details, health data or credentials.
- **Volume and vulnerability.** Children, patients and employees in dispute with you raise the stakes.
- **Ease of misuse.** Was the data encrypted? Could someone identify the individuals?
- **Likely consequences.** Phishing, fraud, identity theft, discrimination, distress.
- **Mitigation.** Can you reduce risk, for example by forcing password resets?

Record your reasoning, **even if you decide the risk is low and do not notify**. Article 33(5) requires you to document all personal data breaches, with the facts, effects and remedial action, so that the authority can verify compliance.

Hours 24 to 72: decide and notify

Decide whether to notify the supervisory authority. If you do, you will normally need to describe:

- The nature of the breach, with categories and approximate numbers of individuals and records.
- The contact details of your data-protection contact.
- The likely consequences.

- The measures taken or proposed.

Where there is a high risk to individuals, prepare the message to them: plain language, what happened, what data, what you are doing, what they should do, and who to contact.

Where you are not sure, ask your supervisory authority, which publishes breach-reporting guidance and forms. Other contract duties may also apply, such as notifying your insurer or your own customers. Check your policy and your agreements in the first day, since insurance terms can require prompt notice.

> **Fictional.** BrightDesk replies on day two: the support database was accessed, ticket text and attachments were included, and logs are incomplete. Harlow & Finch cannot rule out that passport scans were taken. Ines judges the risk to those individuals to be high because identity documents can support fraud. Harlow & Finch notifies its supervisory authority on day three with a phased report, emails the affected clients, forces credential resets and records every decision. Because the studio held no DPA, it also writes to BrightDesk asking for the sub-processor list, a root-cause report and its deletion plan, and starts looking for a replacement.

After the incident

- **Learn.** What would have made this smaller, or caught it sooner?
- **Fix the contract.** If the notification period was too long or missing, renegotiate or switch.
- **Re-tier.** Should the supplier's tier or the data you send change?
- **Update your plan.** Add the supplier's real contact details to your incident plan.
- **Consider compensation and remedies** only with legal advice, as liability depends on the contract and on Article 82.

Be ready before it happens

Prepare a one-page **supplier incident card** for each Tier 1 supplier with: the contract owner, the supplier's security contact, the breach-notification commitment, what data is held, the actions to contain access, and who to tell. Appendix G includes a breach log template.

> **The rule.** The supplier's breach starts your clock. A prepared record turns a crisis into a checklist.

CHAPTER 8

Leaving a Supplier



Step 5 of 5: Exit.

Almost nobody plans how a supplier relationship will end. It ends anyway: a better product, a price rise, a poor security record, a merger, a company that closes. Exit planning is risk management for the one event that is certain.

Why exit is a security issue

Three risks cluster around leaving:

- **Lock-in.** If you cannot get your data out, you cannot leave, however poor the service.
- **Leftover data.** Your data sits in the supplier's systems and backups long after you stopped paying.
- **Leftover access.** Accounts, API keys and integrations stay alive, and nobody remembers them.

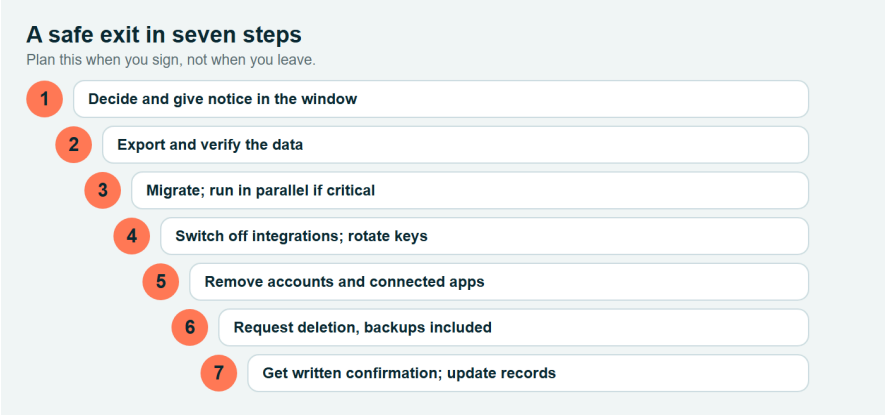
The GDPR addresses the second directly. A processor contract must require the processor, at your choice, to delete or return all personal data after the end of the services and delete existing copies unless law requires storage.[8]

Design the exit when you sign

For Tier 1 suppliers, settle these before you commit:

Question	Why it matters
In what **format** can we export our data?	A proprietary format may be unusable elsewhere
How **long** does an export take, and is there a **fee**?	Delays and costs make leaving hard
How long after termination is data **deleted**, including backups?	Residual copies remain a risk
Will the supplier **confirm deletion** in writing?	You need evidence
What is the **notice period** and are there auto-renewals?	Missing the window locks you in again
Is there a **transition-assistance** commitment?	Helps a safe handover
What happens if the **supplier fails**?	Escrow or export rights reduce exposure

For cloud services, EU law now helps. The Data Act's rules on switching between data-processing services began to apply in September 2025 and are intended to reduce obstacles to switching, including notice periods and exit charges. Check how they apply to your particular service and contract.[19]



A safe exit in seven steps

The exit sequence

1. **Decide and give notice** inside the notice window. Diary the date.
2. **Export your data** and verify it is complete and readable.
3. **Migrate** to the new supplier, with a parallel run if the service is critical.
4. **Switch off integrations** and rotate any API keys or secrets the old supplier knew.
5. **Remove user accounts** and revoke connected-app access.
6. **Request deletion** in writing, including backups, and set a deadline.
7. **Get written confirmation** of deletion, file it, and mark the supplier as ended in your inventory and records of processing.

Appendix F is the offboarding checklist.

When the supplier ends the relationship

Suppliers fail too. If a vendor announces closure or acquisition, treat it as a trigger: export your data now, check what happens to it in a sale, and begin planning a replacement. Do not wait for the last week.

> **The rule.** Know how you will leave before you decide to stay.

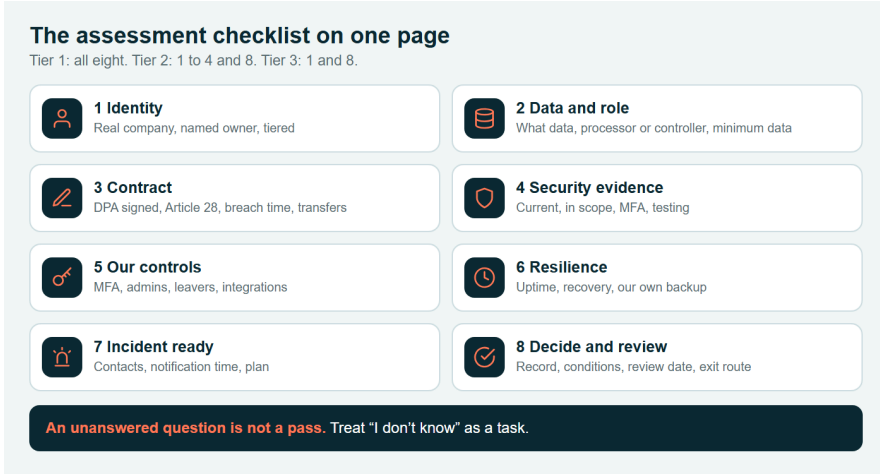
CHAPTER 9

The Practical Supplier Assessment Checklist



This chapter brings the steps together as one checklist you can apply to any supplier. It is deliberately practical: each item is a question you can answer from documents, the supplier's replies or your own settings. A printable version with answer columns is in Appendix C.

Use it in full for Tier 1 suppliers, in part for Tier 2 (sections 1 to 4 and 8), and lightly for Tier 3 (sections 1 and 8).



The supplier assessment checklist on one page

1. Identity and purpose

☐ The supplier is a real, identifiable company with a verifiable address and registration.

- ☐ We know exactly what service we buy and which product or module we use.
- ☐ A named business owner is accountable for the relationship.
- ☐ The supplier is recorded in the inventory with a tier.

2. Data and role

- ☐ We have listed the categories of personal data the supplier will hold or see.
- ☐ We know whether special-category or children's data is involved.
- ☐ We have decided whether the supplier is a **processor**, an independent controller or a joint controller.
- ☐ We send the minimum data needed, and nothing more.
- ☐ We know where the data is stored and who may access it.

3. Contract and GDPR

- ☐ A signed written data-processing agreement is in place before data is sent.
- ☐ It covers the eight Article 28 points (Appendix D).
- ☐ It sets a **time limit for breach notification**, or we have recorded the vendor's stated commitment.
- ☐ Sub-processors are listed, changes are notified, and we know how to object.
- ☐ Transfers outside the EEA or UK are identified and the transfer mechanism is confirmed.
- ☐ The supplier will help with data-subject requests and impact assessments.
- ☐ Deletion or return of data at the end is specified.
- ☐ Liability and insurance are reasonable for the data and risk.

4. Security evidence

- ☐ The supplier states who is responsible for security.
- ☐ Current evidence has been seen: certificate, report or detailed answers.
- ☐ The evidence is in date and covers the service we use.
- ☐ Data is encrypted in transit and at rest.
- ☐ Multi-factor authentication is required for the supplier's staff.
- ☐ Vulnerabilities are patched on a defined schedule and tested independently.
- ☐ Staff with access to our data are screened and trained.

5. Our own account controls

- ☐ Multi-factor authentication is switched on for all our accounts.
- ☐ Admin rights are limited to named people.
- ☐ Accounts are removed when staff, freelancers or agencies leave.
- ☐ Sharing settings, public links and integrations have been reviewed.
- ☐ API keys are stored safely and have an owner.

6. Resilience

- ☐ Uptime and recovery commitments are known and acceptable.
- ☐ We know how long we can operate without the service.
- ☐ A workaround exists for a short outage.
- ☐ We have our own backup or export of critical data.

7. Incident readiness

- ☐ We hold the supplier's security contact and escalation route.
- ☐ We know how quickly they must tell us about a breach.
- ☐ The supplier incident card is filled in.

- ☐ Our own incident plan includes this supplier.

8. Decision and review

- ☐ The decision is recorded: accept, accept with conditions, decline or escalate.
- ☐ Conditions have an owner and a date.
- ☐ The next review date is set.
- ☐ Renewal and notice dates are in the diary.
- ☐ The exit route is known: export format, deletion process, notice period.

Scoring (optional)

If you want a simple number, give each section a rating: **2** if fully met, **1** if partly met, **0** if not met or unknown. Tier 1 suppliers should have no zeros in sections 3 and 4, and any zero must have a written plan. A score is a conversation starter, never a substitute for judgement.

> **The rule.** An unanswered question is not a pass. Treat "I don't know" as a task.

CHAPTER 10

Your 30-Day Supplier Risk Plan



You do not need to fix everything at once. This plan spreads the work across a month so that, at the end, you have an inventory, a tiering, the main contracts in place and a routine to maintain it.



Thirty days to a managed supplier base

Week 1: Map

- ☐ Day 1: Choose one owner for the project and set a weekly one-hour slot.
- ☐ Day 2: Collect twelve months of card, bank and accounts-payable data.
- ☐ Day 3: List every supplier and tool on Appendix A.
- ☐ Day 4: Ask each team what else they use.
- ☐ Day 5: Add business owners, data held and renewal dates.

Done when: you have one list, and every line has an owner.

Week 2: Tier and prioritise

- ☐ Score each supplier with Appendix B.
- ☐ Identify the Tier 1 suppliers.
- ☐ For each, record: DPA in place? Sub-processors known? Transfers known?
- ☐ Rank the gaps. Put missing DPAs and unknown data locations first.

Done when: you can name your five most important suppliers and the three biggest gaps.

Week 3: Test and bind

- ☐ Run the Chapter 9 checklist on the top three Tier 1 suppliers.
- ☐ Send the Appendix E short questionnaire where evidence is missing.
- ☐ Download, read and sign the vendors' DPAs. Check the Appendix D clauses.
- ☐ Switch on multi-factor authentication for every account you control.
- ☐ Record decisions, conditions and review dates.

Done when: your top three suppliers have a written decision and a signed DPA.

Week 4: Watch and exit

- ☐ Subscribe to sub-processor and security notices for Tier 1 suppliers.
- ☐ Fill in a supplier incident card for each Tier 1 supplier.
- ☐ Add supplier breaches to your incident plan.
- ☐ Note exit routes: export format, deletion process, notice dates.
- ☐ Diary the annual review and renewal dates.

- ☐ Add a short "new supplier" gate: no data until the one-page check is done.

Done when: a new supplier request can only reach live data through the one-page check.

After day 30

Hold a quarterly thirty-minute review. Add new suppliers, remove ended ones, check changes and record the lessons. Then work down the Tier 2 list.

A word on perfection

You will not find every gap, and some suppliers will refuse to negotiate. The aim is not a flawless programme but a demonstrable one: you know your suppliers, you have assessed the important ones, you have contracts where the law requires them, and you are watching. That is a defensible position, and a safer business.

CHAPTER 11

Five Case Files



> **Fictional.** All five cases are invented. They are built to practise decisions, not to describe real organisations.

For each case, read the facts, answer the questions, then compare with the suggested approach.

Case 1: The free plan nobody approved

Facts. A marketing manager at a 20-person firm signs up to a free form-builder to run a prize-draw. The tool collects names, email addresses and birth dates from 4,000 entrants. The terms say the provider may use submitted data to "improve our services and for related purposes". There is no DPA.

Questions. Is the provider a processor? What is wrong with the terms? What should happen to the 4,000 records?

Suggested approach. If the provider uses data for its own purposes, it may be acting as a controller for those purposes, and the company has no compliant processor contract. The company should stop collecting through this tool, move to an approved form product with a DPA, and review the lawful basis and notices for the prize-draw. Export and delete the data from the free plan after migration. Add a fast approval route so the next campaign uses the right tool.

Case 2: The payroll bureau

Facts. A small manufacturer outsources payroll to a two-person bureau. The bureau holds names, addresses, bank details and absence records for 60 staff, emails spreadsheets to the owner and uses a personal webmail account. There is no written agreement.

Questions. What tier is this supplier? What risks stand out? What should the owner do first?

Suggested approach. Tier 1: sensitive data, essential function, a very small supplier. Priorities: put a written DPA in place; move file exchange to a secure portal or encrypted channel; require multi-factor authentication on the bureau's accounts; confirm backup and continuity arrangements for payroll; agree breach notification within a fixed time. Document the decision to continue.

Case 3: The cloud tool that added AI

Facts. A therapist's practice uses a cloud scheduling and notes tool. An email announces "AI note summaries" that will be switched on for all customers next month. The provider's updated terms list a new third-party model provider as a sub-processor, with processing in another region.

Questions. What kind of data is at stake? What triggers a reassessment? What should be asked?

Suggested approach. Notes may contain special-category health data, raising the stakes. Treat the announcement as a trigger: ask which provider processes the notes, whether data is used for training, where it is processed and how long it is kept; confirm the transfer mechanism for the new region; ask whether the feature can be switched off at account level; and check whether a data-protection impact assessment needs updating. If answers are unsatisfactory, disable the feature or move to another tool.

Case 4: The supplier that told us on day five

Facts. An online shop's fulfilment partner discovers that an unauthorised party accessed a customer address database. It tells the shop five days later. The shop's contract says only that the partner will notify "promptly".

Questions. When did the shop's 72 hours start? What is wrong with the contract? What should the shop do now?

Suggested approach. The shop's clock starts when it becomes aware, which is day five, though the delay will itself be scrutinised, and the partner has failed its own duty to notify without undue delay. Assess risk to customers, notify the authority within 72 hours of awareness with a phased report and decide on notifying individuals. Afterwards, renegotiate for a fixed notification period such as 24 to 48 hours, or move to a supplier that will commit.

Case 5: The agency with the keys

Facts. A small charity gave its web agency admin access to the CRM and donor email platform. The relationship ended a year ago. A routine review finds the agency's three staff logins are still active and an API key is still in use by an integration nobody remembers.

Questions. What are the risks? What should be done today? What process failed?

Suggested approach. Disable the accounts and rotate the API key immediately, then review logs for unusual activity since the contract ended. Check what donor data the agency may still hold and request written deletion. The failure was the lack of an exit checklist: Appendix F would have caught the accounts and keys. Add offboarding to every supplier ending and review access quarterly.

Conclusion: Trust, Verified



Every business runs on other businesses. That is not a flaw to eliminate; it is how modern work gets done. The aim of this book was never to make you suspicious of your suppliers. It was to make your trust *informed*.

If you remember five things, remember these:

1. **You remain responsible.** Handing data to a supplier does not hand over your duty.
2. **Map first.** You cannot protect what you have not listed.
3. **Proportion matters.** Spend effort where the damage would be greatest.
4. **Contracts and evidence both count.** An Article 28 agreement says what must happen; assessment tells you whether it is likely to.
5. **Plan for the bad day.** Know who to call, how fast the clock runs and how you would leave.

Start small. Pick the one supplier whose failure would hurt most, and run the checklist on it this week. Then do the next. Within a month you will have something many larger organisations still lack: a clear, written picture of who holds your data, on what terms, and what you would do if they failed.

> **The rule.** Trust your suppliers the way you would trust a bridge: because someone checked, and keeps checking.

APPENDIX A

Supplier Inventory Template

Copy one row per supplier. Keep it in a spreadsheet and review it quarterly.

Field	Entry
Supplier name and product	_____
Business owner	_____
Purpose (what it does for us)	_____
Date started / renewal date / notice period	_____
Personal data held (categories)	_____
Data subjects (customers, staff, others)	_____
Special-category or children's data?	Yes / No
Approximate number of individuals	_____
Role: processor / controller / joint	_____
DPA signed? (date, location of file)	_____
Sub-processors listed? (date checked)	_____
Hosting location(s)	_____
Transfers outside EEA/UK and mechanism	_____
Security evidence on file (type, date, scope)	_____
MFA enabled on our accounts?	Yes / No
Users with access / admins	_____
Integrations and API keys	_____
Tier (1, 2, 3)	_____
Last review date / next review	_____
Exit route (export format, deletion)	_____
Notes	_____

APPENDIX B

Supplier Tiering Sheet

Score each supplier from 1 (low) to 3 (high) on each question. Add the scores.

Question	1	2	3
Data sensitivity. What is the most sensitive data they hold?	None or public	Contact or business data	Financial, health, ID, credentials, children
Volume. How many people's data?	Few	Hundreds	Thousands or more
Dependence. How long could we operate without them?	Weeks, easily replaced	A few days	Hours; critical process
Access. What access do they have to our systems?	None	Limited	Wide or administrative
Replaceability. How hard to replace?	Easy	Some effort	Very hard, locked in

Total 5 to 7: Tier 3. **8 to 11:** Tier 2. **12 to 15:** Tier 1.

Override rule. Any supplier that holds special-category data, or is essential to a critical process, is Tier 1 regardless of score.

Record the score, the tier and the date in Appendix A.

APPENDIX C

Supplier Assessment Record

Use this alongside the Chapter 9 checklist. Fill one in per supplier.

Supplier: _____ **Tier:** _____ **Owner:** _____

Date: _____

Section	Rating (0, 1, 2)	Evidence seen	Gaps and actions	Owner and date
1. Identity and purpose				
2. Data and role				
3. Contract and GDPR				
4. Security evidence				
5. Our account controls				
6. Resilience				
7. Incident readiness				
8. Decision and review				

Decision: Accept / Accept with conditions / Decline / Escalate

Conditions and deadlines:

_____

_____

Decided by: _____ **Next review:** _____

APPENDIX D

Processor Agreement Checklist (Article 28)

Tick each point when you have found it in the contract and noted the clause number.

Description of processing

- ☐ Subject matter and duration
- ☐ Nature and purpose
- ☐ Type of personal data
- ☐ Categories of data subjects
- ☐ Controller's obligations and rights

Processor obligations (Article 28(3))

- ☐ (a) Processes only on documented instructions, including on transfers
- ☐ (a) Must tell the controller if an instruction infringes the GDPR
- ☐ (b) Personnel committed to confidentiality
- ☐ (c) Appropriate security measures (Article 32)
- ☐ (d) Sub-processor authorisation, notice of changes and right to object
- ☐ (d) Same obligations passed to sub-processors, with the processor liable
- ☐ (e) Assistance with data-subject requests
- ☐ (f) Assistance with security, breach notification, impact assessments and prior consultation
- ☐ (g) Deletion or return of data at the end, at the controller's choice

- ☐ (h) Information to demonstrate compliance, and audits or inspections

Practical additions worth seeking

- ☐ Fixed time for breach notification to us, such as 24 to 48 hours
- ☐ Named contact for security incidents
- ☐ Sub-processor list, with a notification route for changes
- ☐ Transfer mechanism stated, with Standard Contractual Clauses attached where needed
- ☐ Prohibition on using our data for the processor's own purposes
- ☐ Deletion timetable, including backups, and written confirmation
- ☐ Liability cap proportionate to the data involved

Result: Complete / Gaps to raise with the supplier: _____

APPENDIX E

Short Supplier Security Questionnaire

Send this to Tier 1 and Tier 2 suppliers when their public materials do not already answer it. Ask for answers and, where marked, evidence.

A. Governance

1. Who is responsible for information security in your organisation?
2. Do you hold a current ISO/IEC 27001 certificate, SOC 2 Type II report or equivalent? Please send it and state which services and locations it covers.

B. Access

3. Is multi-factor authentication required for your staff on systems that can reach customer data?
4. Do you offer or enforce multi-factor authentication and single sign-on for customers?
5. How is staff access to customer data limited and logged?

C. Data protection

6. Is customer data encrypted in transit and at rest? Who manages the keys?
7. In which countries is our data stored and accessed, including by support staff?
8. Please send your current sub-processor list. How will you notify us of changes?

D. Vulnerability and testing

9. How often are systems tested by an independent party? Can you share a summary?

0. What is your target time to patch critical vulnerabilities?

E. Incidents

1. Do you have a tested incident-response plan?
2. How quickly will you notify us of a breach affecting our data, and to whom?

F. Resilience

3. What are your uptime commitment, backup frequency and recovery targets?

G. AI and data use

4. Do you use our data to train or improve any models, yours or a third party's?
5. Which AI or model providers, if any, process our data?

H. Exit

6. In what format and timescale can we export our data?
7. How long after termination do you delete our data, including backups, and will you confirm in writing?

APPENDIX F

Supplier Offboarding Checklist

Supplier: _____ **Exit date:** _____ **Owner:** _____

Before the end

- ☐ Notice given inside the contractual window; date diarised
- ☐ Replacement chosen, assessed and under contract
- ☐ Full data export requested
- ☐ Export checked for completeness and usable format
- ☐ Data migrated; parallel run complete if critical

At the end

- ☐ User accounts removed for staff, freelancers and agencies
- ☐ Single sign-on and connected-app access revoked
- ☐ Integrations switched off
- ☐ API keys and shared secrets rotated or revoked
- ☐ Payment method removed from the supplier account

After the end

- ☐ Written deletion request sent, including backups
- ☐ Deadline for deletion agreed
- ☐ Written confirmation of deletion received and filed
- ☐ Inventory updated: supplier marked as ended
- ☐ Record of processing activities updated
- ☐ Privacy notice updated if processors or transfers changed
- ☐ Lessons noted for the next procurement

APPENDIX G

Supplier Breach Log

Complete in real time. Keep a copy even if you decide not to notify.

Item	Entry
Supplier and service	_____
Date and time we were told / how / by whom	_____
Date and time breach began / ended (per supplier)	_____
Data affected (categories, approximate numbers)	_____
Was the data encrypted or protected?	_____
Containment actions by supplier	_____
Containment actions by us (resets, key rotation)	_____
Likely consequences for individuals	_____
Risk assessment: unlikely / risk / high risk	_____
Reasoning	_____
Decision on notifying the authority (and time)	_____
Decision on notifying individuals (and time)	_____
Insurer / other parties notified	_____
Follow-up questions to supplier and answers	_____
Contract and process changes agreed	_____
Review date	_____

Glossary

Adequacy decision. A European Commission decision that a non-EU country, or a framework within it, ensures an adequate level of data protection, allowing transfers without further safeguards.

Controller. The organisation that decides why and how personal data is processed.

Data-processing agreement (DPA). The contract between a controller and a processor required by Article 28 of the GDPR.

Fourth party. A supplier of your supplier. Where it processes your personal data it is usually a sub-processor.

ISO/IEC 27001. An international standard for information-security management systems, certified by independent auditors.

Joint controllers. Two or more controllers who jointly decide the purposes and means of processing.

Processor. An organisation that processes personal data on behalf of a controller and on its instructions.

Shared responsibility model. The split of security duties between a cloud provider and its customer.

Shadow IT. Tools adopted by staff without the organisation's knowledge or approval.

SOC 2. A US-originated attestation framework for service organisations. Type I reports describe control design at a point in time; Type II reports test operating effectiveness over a period.

Standard Contractual Clauses (SCCs). Model contract terms approved by the European Commission for transfers of personal data outside the EEA.

Sub-processor. A processor engaged by another processor to carry out processing for a controller.

Supervisory authority. The national data-protection regulator, such as the ICO in the UK or the CNIL in France.

Third-party risk. The risk that a supplier, partner or other outside party exposes your organisation to loss, disruption or non-compliance.

A Note on GDPRGard.eu

Supplier risk sits beside a wider question: what does the GDPR expect of a small business? If this book has raised questions about processor agreements, data-subject requests, breach reporting or records of processing, **GDPRGard.eu** offers free tools, guides and articles for European small businesses, written in plain English. It is a good place to continue after the 30-day plan.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that business owners should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Visit **gdprgard.eu** for free tools, articles and updates. If this guide helped you, an honest review where you bought it helps other readers find it.

Notes and Sources

Research cut-off: 30 October 2026. Items marked (read) were consulted for this edition; the others rest on the author's working knowledge of well-known public records and should be re-checked against the primary source before you rely on them.

1. Regulation (EU) 2016/679 (GDPR), Articles 33 and 34; EDPB Guidelines 9/2022 on personal data breach notification. eur-lex.europa.eu; edpb.europa.eu.
2. Reporting on the 2013 Target breach and the role of a refrigeration contractor's credentials, including US Senate Commerce Committee staff report (2014).
3. CISA and public vendor advisories on the SolarWinds Orion supply-chain compromise, December 2020.
4. Public advisories on the Kaseya VSA incident, July 2021 (CISA / FBI guidance).
5. CISA advisory on MOVEit Transfer exploitation (Clop), June 2023.
6. ICO, "Capita fined £14m for data breach affecting over 6m people", October 2025 (read). ico.org.uk.
7. CrowdStrike, public post-incident review of the 19 July 2024 content update; Microsoft statement on the number of affected Windows devices.
8. GDPR Article 28, "Processor". eur-lex.europa.eu.
9. EDPB Opinion 22/2024 on certain obligations following from the reliance on processor(s) and sub-processor(s), adopted October 2024 (secondary commentary read; primary text should be checked at edpb.europa.eu).
10. ISO/IEC 27001:2022; AICPA SOC 2 guidance on Type I and Type II reports.
11. EDPB Guidelines 07/2020 on the concepts of controller and processor in the GDPR.
12. Commission Implementing Decision (EU) 2023/1795 on the adequate level of protection under the EU–US Data Privacy Framework (10 July 2023); General Court judgment of 3 September 2025 in Case T-553/23 Latombe v Commission; appeal pending as Case C-703/25 P (reporting read to June 2026). Data Privacy Framework List: dataprivacyframework.gov.

13. Commission Implementing Decision (EU) 2021/914 on standard contractual clauses; Court of Justice, Case C-311/18 (Schrems II), 16 July 2020.
14. GDPR Article 82, "Right to compensation and liability".
15. GDPR Article 83(4) and 83(5), "Administrative fines".
16. Mandiant (Google Cloud) public reporting on the 2024 Snowflake customer-account data thefts and the absence of multi-factor authentication on affected accounts.
17. Regulation (EU) 2022/2554 (Digital Operational Resilience Act), applicable from 17 January 2025.
18. Directive (EU) 2022/2555 (NIS2), Article 21(2)(d), supply-chain security.
19. Regulation (EU) 2023/2854 (Data Act), Chapter VI on switching between data-processing services, applicable from 12 September 2025.